

TUGAS PERTEMUAN 6
AUDIT SISTEM INFORMASI



Disusun oleh:

Rama Pramudya Wibisana

2022320019

PROGRAM STUDI SISTEM INFORMASI

FAKULTAS INFORMATIKA

UNIVERSITAS BINA INSANI

BEKASI

2024

1. Menurut COSO, *Enterprise Risk Management* (ERM) adalah prosedur yang diawasi oleh manajemen perusahaan untuk menemukan, menilai, dan mengelola risiko yang dapat menghambat pencapaian tujuan organisasi. ERM—Kerangka Kerja Terintegrasi adalah pedoman lengkap untuk manajemen risiko yang menjelaskan komponen penting untuk meminimalkan dampak risiko pada seluruh operasi bisnis.
2. Berikut delapan komponen *Enterprise Risk Management* (ERM) menurut Kerangka Kerja COSO, yang membantu organisasi mengidentifikasi, menilai, dan mengelola risiko secara menyeluruh:

a. Lingkungan Internal (Internal Environment)

Dalam proses ERM, lingkungan internal menentukan bagaimana risiko dilihat dan dihadapi dalam setiap keputusan. Lingkungan ini mencakup nilai, budaya, integritas, dan filosofi organisasi, serta sikap manajemen terhadap risiko, serta struktur organisasi.

b. Penetapan Tujuan (Objective Setting)

Tujuan yang ditetapkan oleh manajemen harus sesuai dengan visi dan misi organisasi. Tujuan ini dalam konteks ERM membantu organisasi dalam menentukan risiko yang dapat mempengaruhi pencapaian tujuan. Jenis tujuan yang berbeda termasuk tujuan strategis, operasional, pelaporan, dan kepatuhan. Proses ini memastikan bahwa setiap tujuan yang ditetapkan sudah sejalan dengan kapasitas risiko dan strategi perusahaan.

c. Identifikasi Peristiwa (Event Identification)

Dalam proses ini, peristiwa yang dapat mempengaruhi pencapaian tujuan organisasi diidentifikasi. Peristiwa tersebut dapat dianggap positif (peluang) atau negatif (risiko). Definisi ini mengacu pada berbagai faktor eksternal dan internal yang dapat menyebabkan risiko, seperti lingkungan ekonomi, regulasi baru, pasar, atau perubahan teknologi.

d. Penilaian Risiko (Risk Assessment)

Pada titik ini, organisasi melakukan penilaian risiko untuk menilai sejauh mana risiko tersebut dapat memengaruhi pencapaian tujuan. Penilaian risiko biasanya dilakukan dengan menilai kemungkinan dan efek dari setiap risiko, yang kemudian menentukan prioritas risiko berdasarkan tingkat keparahannya. Baik metode kuantitatif maupun kualitatif dapat digunakan untuk melakukan analisis ini.

e. Tanggapan Risiko (Risk Response)

Setelah penilaian risiko selesai, organisasi perlu menentukan cara menanggapi risiko tersebut. Pilihan tanggapan risiko biasanya meliputi:

- **Menghindari:** Menghindari aktivitas yang memiliki risiko tinggi.
- **Mengurangi:** Mengurangi dampak risiko dengan tindakan pencegahan.
- **Berbagi:** Mengalihkan sebagian atau seluruh risiko kepada pihak lain (misalnya, dengan asuransi).
- **Menerima:** Menerima risiko jika dianggap masih dalam batas yang dapat ditanggung.

f. Kegiatan Pengendalian (Control Activities)

Ini adalah tindakan yang diambil untuk memastikan tanggapan risiko dilakukan dengan baik. Pengendalian adalah kumpulan tindakan, proses, dan kebijakan yang dimaksudkan untuk mengurangi risiko. Tinjauan berkala atas aktivitas yang berisiko, persetujuan atas transaksi besar, atau pembatasan akses terhadap data sensitif adalah beberapa contohnya.

g. Informasi dan Komunikasi (Information and Communication)

Ini adalah bagian yang memastikan bahwa informasi tentang risiko disampaikan dengan tepat kepada pihak-pihak yang relevan di dalam organisasi. Sebuah sistem komunikasi yang baik memungkinkan informasi tentang risiko, kontrol, dan respons untuk sampai ke semua tingkatan manajemen secara efisien. Pelaporan risiko berkala dan komunikasi antardepartemen adalah contohnya.

h. Pemantauan (Monitoring)

Tinjauan berkala, audit internal, atau pemeriksaan independen digunakan untuk memantau operasi ERM. Tujuannya adalah untuk memastikan bahwa metode dan tindakan yang digunakan berhasil dalam mengurangi risiko dan memberi manajemen kemampuan untuk menyesuaikan diri dengan keadaan saat ini.

3. NIST menggambarkan manajemen risiko sebagai metode sistematis untuk mengidentifikasi, menilai, dan mengendalikan ancaman yang mengancam keamanan, integritas, dan aksesibilitas informasi. Dengan menerapkan manajemen risiko, organisasi dapat mengurangi dampak yang dapat ditimbulkan oleh ancaman terhadap keamanan, integritas, dan aksesibilitas informasi.
4. Penilaian risiko adalah proses mengidentifikasi dan mengevaluasi risiko yang dapat mempengaruhi pencapaian tujuan organisasi. Proses ini melibatkan analisis dampak dan peluang untuk menentukan prioritas penanganan risiko.
5. Panduan NIST memungkinkan organisasi untuk meningkatkan keamanan dan pertahanan TI mereka serta mengurangi kemungkinan pelanggaran keamanan dengan membantu mereka menerapkan kontrol keamanan yang sistematis, menetapkan praktik terbaik, dan menyediakan kerangka kerja untuk menilai dan memitigasi risiko.
6. Contoh Sumber Daya untuk Alat dan Teknik Identifikasi dan Evaluasi Risiko TI
 - Framework NIST SP 800-30: Pedoman untuk penilaian risiko yang membantu dalam mengidentifikasi risiko dan kontrol yang diperlukan.
 - ISO/IEC 27001: Standar internasional yang menyediakan pendekatan sistematis untuk melindungi informasi.
 - Software Risk Assessment Tools: Seperti RSA Archer, menyediakan penilaian risiko otomatis.
 - Threat Intelligence Platforms: Memberikan informasi ancaman untuk membantu dalam identifikasi risiko dan penyusunan strategi mitigasi.

7. Pengendalian aktivitas adalah tindakan-tindakan operasional yang digunakan untuk memitigasi risiko dalam proses bisnis. Jenis pengendalian meliputi:
 - Pengendalian Preventif: Mencegah terjadinya risiko
 - Pengendalian Detektif: Mengidentifikasi risiko yang sudah terjadi.
 - Pengendalian Korektif: Mengatasi dampak risiko yang sudah terjadi.
 - Pengendalian Compensating: Melakukan pembenahan jika pengendalian utama tidak berjalan.
8. Dengan mengurangi risiko dan memberikan kompensasi finansial saat terjadi insiden, asuransi membantu perusahaan mengalihkan beban risiko finansial kepada pihak asuransi, memungkinkan perusahaan untuk lebih fokus pada bisnis inti mereka.
9. Polis asuransi TI biasanya mencakup biaya perbaikan pasca-insiden, kehilangan data, gangguan operasi, serta kemungkinan litigasi karena pelanggaran data. Mereka juga mencakup pemulihan aset digital dan layanan forensik untuk mengidentifikasi sumber insiden.
10. Asuransi siber berbeda dari asuransi tanggung jawab umum komersial karena dirancang khusus untuk melindungi perusahaan dari risiko siber seperti pelanggaran data dan serangan siber. Ini karena risiko siber seringkali bersifat dinamis dan membutuhkan pengamanan yang lebih khusus, yang tidak termasuk dalam asuransi konvensional.